NEBULA TEKNOLOJİ A.Ş.

Parola ve Erişim Yönetimi Politikası

Sürüm 2.0 — v1.3 (2025) sürümünün yerini alır

Doküman No	BT-POL-002
Sürüm	2.0
Sahibi	Emre Kaya, BT Müdürü
Hazırlayan	Murat Şen, Sistem Yöneticisi
Onaylayan	Mehmet Yılmaz, CEO
Yürürlük	1 Mart 2026
Yayın Tarihi	16.02.2026
Gizlilik	Şirket İçi

1. Amaç

Bu politika, Nebula Teknoloji A.Ş. bünyesindeki tüm kurumsal sistemlere, NebulaCRM üretim ortamına ve müşteri verisine erişimde kullanılan kimlik doğrulama yöntemlerini ve erişim yetkilerinin yaşam döngüsünü tanımlar. Politika, ISO/IEC 27001:2022 Ek A kontrolleri 5.15–5.18 ve 8.5 ile uyumlu olacak şekilde hazırlanmıştır.

Sürüm 2.0, 15 Ocak 2025'te yürürlüğe giren v1.3 sürümünün yerini alır. Güncellemenin temel gerekçesi, zorunlu periyodik parola değişiminin kullanıcıları tahmin edilebilir parolalara yönelttiğinin iç denetimde tespit edilmesi ve çok faktörlü kimlik doğrulamanın (MFA) yalnızca VPN ve e-posta ile sınırlı kalmasının kabul edilemez bir risk olarak değerlendirilmesidir.

2. Kapsam

Politika; tüm çalışanları, stajyerleri, Nebula Technology GmbH personelini, yükleniciler ile danışmanları ve şirket adına sistemlere erişen tüm üçüncü tarafları kapsar. İstanbul, Ankara, İzmir ve Berlin ofislerinde ayrım yapılmaksızın uygulanır. Müşterilerin NebulaCRM içindeki son kullanıcı hesapları bu politikanın kapsamı dışındadır; bu hesaplar için ürün içi parola kuralları müşteri yöneticileri tarafından yapılandırılır.

3. Parola Kuralları

- Kullanıcı parolaları en az 14 karakter uzunluğunda olmalıdır. Karakter türü zorunluluğu aranmaz; dört veya daha fazla rastgele kelimeden oluşan parola cümleleri önerilir.
- Parolalar periyodik olarak değiştirilmez. Parola yalnızca ele geçirildiğinden şüphelenildiğinde, bir güvenlik olayı sonrasında veya BT ekibinin talebiyle değiştirilir.
- Yeni parola, sızdırılmış parola listesine karşı otomatik olarak kontrol edilir; listede yer alan parolalar kabul edilmez.
- Parola geçmişi son 12 parolayı tutar; bu parolalar yeniden kullanılamaz.
- Art arda 10 hatalı giriş denemesinden sonra hesap 15 dakika süreyle kilitlenir.
- Tüm çalışanlar kurumsal parola kasasını kullanmak zorundadır; parolaların tarayıcıda, not dosyalarında veya kağıt üzerinde saklanması yasaktır.
- Ekran kilidi, 10 dakika hareketsizlikten sonra otomatik olarak devreye girer.

4. Çok Faktörlü Kimlik Doğrulama

1 Mart 2026 itibarıyla MFA, kimlik sağlayıcıya bağlı tüm sistemlerde zorunludur: e-posta, VPN, kurumsal mesajlaşma, kod deposu, CI/CD platformu, İK portalı, finans uygulamaları ve NebulaCRM yönetim konsolu dahil. SMS ile tek kullanımlık kod, yalnızca yedek yöntem olarak ve en fazla 7 gün süreyle kullanılabilir.

Yönetici (privileged) hesaplar için FIDO2 donanım güvenlik anahtarı zorunludur. Her yöneticiye biri yedek olmak üzere iki anahtar teslim edilir. Kayıp anahtar 24 saat içinde BT Yardım Masası'na bildirilmeli ve anahtar kimlik sağlayıcıdan derhal iptal edilmelidir.

5. Servis Hesapları ve Makine Sırları

Servis hesaplarının parolaları, API anahtarları ve sertifika özel anahtarları merkezi sır yönetim sistemi üzerinden dağıtılır. Servis hesabı sırları en geç 180 günde bir döndürülür; ödeme ve kimlik doğrulama hizmetlerine ait sırlar için bu süre 90 gündür. Sır döndürme işlemi çift anahtar yöntemiyle yapılır: yeni anahtar devreye alınıp tüm tüketiciler doğrulanmadan eski anahtar iptal edilmez. Bu kural, INC-2026-0417 kesintisinden çıkarılan dersler doğrultusunda Nisan 2026'da eklenmiş ve v2.0'ın 2.0.1 ara revizyonuyla duyurulmuştur.

6. Erişim Yaşam Döngüsü

1. Erişim talepleri BT Portalı üzerinden açılır; talep, çalışanın yöneticisi ve ilgili sistem sahibi tarafından onaylanır.
2. Geçici hesaplar (yüklenici, denetçi, stajyer) en fazla 30 gün için açılır ve süre sonunda otomatik olarak devre dışı kalır.
3. İşten ayrılan çalışanın tüm hesapları, İK'nın ayrılış kaydını girmesinden itibaren en geç 4 saat içinde devre dışı bırakılır.
4. Departman değişikliğinde eski rol yetkileri 5 iş günü içinde kaldırılır.
5. Ayrıcalıklı erişimler üç ayda bir, diğer erişimler yılda iki kez sistem sahipleri tarafından gözden geçirilir.

Acil durum (break-glass) için iki adet yönetici hesabı tanımlıdır. Bu hesapların kimlik bilgileri Maslak genel merkezindeki kasada mühürlü zarfta saklanır, her kullanımda CEO Ofisi ve BT Müdürü bilgilendirilir ve hesaplar altı ayda bir test edilir.

7. v1.3 → v2.0 Değişiklik Özeti

Kural	v1.3 (2025)	v2.0 (2026)
Minimum parola uzunluğu	12 karakter	14 karakter
Periyodik değişim	90 günde bir	Yalnızca şüphe halinde
Hesap kilitleme	5 deneme / 30 dakika	10 deneme / 15 dakika
Parola geçmişi	Son 5 parola	Son 12 parola
MFA kapsamı	VPN ve e-posta	Tüm sistemler
Yönetici MFA yöntemi	Mobil uygulama kodu	FIDO2 güvenlik anahtarı
Servis hesabı sırları	Yılda bir	180 günde bir
Ekran kilidi	15 dakika	10 dakika
Ayrılan çalışan hesabı	24 saat içinde	4 saat içinde

Tablo 1 — Sürümler arası başlıca farklar. v1.3, 1 Mart 2026 itibarıyla yürürlükten kalkmıştır.

8. Uyum ve İstisnalar

Politikaya istisna talepleri, gerekçe ve telafi edici kontrollerle birlikte BT Portalı üzerinden Emre Kaya'ya iletilir. Onaylanan istisnalar en fazla 6 ay geçerlidir ve risk kaydına işlenir. Politikaya aykırılık, disiplin yönetmeliği çerçevesinde değerlendirilir. Uyum durumu her çeyrek sonunda Kalite Müdürlüğü'ne raporlanır; 2026 ilk çeyreğinde MFA kapsamı %99,2 olarak ölçülmüştür.